SE Lab Report - Lab 5 : Static Code Analysis

PES1UG24CS401 - Saiesh Shankar

Gitrepo of All submissions : https://github.com/SaieshShankar/SE-Labs-GitRepo_PES1UG24CS401

Gitrepo of This submission : https://github.com/SaieshShankar/L5_37_todo_manager

Brief Introduction -

What is static code analysis ?

Static code analysis is a method of inspecting computer source code, byte code, or binary files for bugs, security vulnerabilities, and code quality issues without executing the program**.**

Pylint: checks code quality, logical issues and coding conventions.
Bandit: detects potential security vulnerabilities.
Flake8: checks PEP 8 formatting and style violations.

```
No task with id 99
Pending tasks: ['Submit lab report', 'Book train tickets', 'Call plumber']
Task id for 'plumber': 3
Task id for 'gym': None
Try this next: Book train tickets
Tasks restored from file: 4
Exported tasks to tasks.json
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager> python -m pylint todo_manager.py > pylint_before.txt
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager>
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager> python -m bandit -r todo_manager.py > bandit_before.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.5
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager>
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager> python -m flake8 todo_manager.py > flake8_before.txt
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager> python todo_manager.py
No task with id 99
Pending tasks: ['Submit lab report', 'Book train tickets', 'Call plumber']
Task id for 'plumber': 3
Task id for 'gym': None
Try this next: Call plumber
Tasks restored from file: 4
Exported tasks to tasks.json
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager>
(venv) PS C:\Users\Saiesh Shankar\L5_37_todo_manager> python -m pylint todo_manager.py
************* Module todo_manager
todo_manager.py:124:0: C0305: Trailing newlines (trailing-newlines)
todo_manager.py:17:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:69:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:74:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:80:0: C0116: Missing function or method docstring (missing-function-docstring)
todo_manager.py:91:0: C0116: Missing function or method docstring (missing-function-docstring)

-------------------------------------------------------------------
Your code has been rated at 8.45/10 (previous run: 5.09/10, +3.36)
```

Initially - it was at 5.09 / 10
Then it was improved to 8.45 / 10 on the first run.



Then it was improved to 10 / 10

As outlined in the initial reports, the main issues were :

Pylint

- Missing module and function docstrings.
- Incorrect naming conventions (camelCase instead of snake_case).
- Mutable default argument (labels=[]).
- Inconsistent return statements.
- Missing file encoding.

Bandit

- B403: Unsafe pickle module import.
- B301: Unsafe pickle deserialization.
- B605: Potential shell command injection through os.system().
- B311: Standard random generator warning.

Flake8

- E225: Missing whitespace around operator.
- E303: Too many blank lines.
- E261: Incorrect spacing before inline comment.
- E231: Missing whitespace after comma.

Issue	Tool	Description	Fix
Mutable default argument	Pylint	Shared mutable list	Changed [] to None

Unsafe deserialization	Bandit	Use of pickle.load()	Replaced with json.load()
Shell injection risk	Bandit	Unsafe os.system()	Removed shell execution
Missing docstrings	Pylint	Functions lacked documentation	Added docstrings
Insecure random generator warning	Bandit	random.choice() flagged B311	Replaced with secrets.choice()
Trailing blank line	Flake8	W391 formatting violation	Removed extra blank line

Reflection

1. What is static code analysis?

Static code analysis examines source code without executing it to identify potential bugs, security vulnerabilities and coding standard violations.

2. What is the difference between Pylint, Bandit and Flake8?

Pylint focuses on code quality and logical issues. Bandit identifies common security vulnerabilities. Flake8 checks Python code against formatting and PEP 8 style guidelines.

3. What issues did you identify and fix?

I identified mutable default arguments, unsafe pickle deserialization, unsafe shell command execution, unused variables and formatting violations. I addressed these issues by modifying the implementation and following safer coding practices.

4. How does static code analysis improve software development?

Static analysis helps identify problems early, improves code readability and maintainability, reduces security risks and encourages consistent coding standards.